

CSW Proof-of-Value Findings — acme

Generated 2026-05-01T18:30:00Z from live evidence in `https://csw.acme-demo.local`.
Use this as the talk-track for the readout meeting; it is intentionally denser than the CISO brief.

What we looked at

In a single read of the tenant we collected:

Signal	Count
Workloads inventoried	4,820
Workloads reporting via agent	4,612 (95.7%)
Scopes in hierarchy	47
Policies authored	312
Policies in enforce mode	248
Absolute policies (highest precedence)	41
Critical CVEs on workloads	7
High CVEs on workloads	64
Enforcement alerts in 24h	24

The same evidence bundle is replayable; nothing here was hand-curated.

Posture at a glance

Score: 75 / 100 (Grade C)

- **Visibility — 24 pts.** 4612/4820 workloads reporting (95.7% agent coverage).
 - **Segmentation — 18 pts.** 312 policies, 248 in enforce mode (79%), 41 absolute (13%).
 - **Hygiene — 12 pts.** 7 critical, 64 high CVEs detected on workloads.
 - **Operations — 13 pts.** 24 enforcement alerts in last 24h.
 - **Compliance — 8 pts.** 21/25 controls marked 'met' across 4 frameworks.
-

What you're already doing well

Agent coverage at 95.7%

Strong agent coverage means flow analytics, ADM recommendations, and policy enforcement are operating on the real estate, not a sample.

Compliance reinforcement. This capability supports:

- **HIPAA** — 164.308(a)(1)(ii)(A) (risk analysis requires knowing what's in scope); 164.310(c) (workstation security depends on inventory)
- **PCI-DSS** — 1.2.1 (network controls depend on knowing what they protect)
- **NIST-800-53** — AU-2 (audit events presume coverage of every workload); SI-4 (system monitoring requires telemetry from every workload)
- **DORA** — Art.8 (ICT risk management requires complete asset inventory); Art.9 (ICT security depends on knowing the estate)

312 policies authored

A populated policy library indicates segmentation is past initial discovery and into active design.

Compliance reinforcement. This capability supports:

- **HIPAA** — 164.308(a)(4) (information access management is enforced via policy); 164.312(a)(1) (access control is implemented as policy)
- **PCI-DSS** — 1.2.1 (network security controls are the segmentation evidence); 1.3 (no direct internet access to CDE requires enforced policy); 12.5.3 (segmentation effectiveness is tested annually)
- **NIST-800-53** — AC-3 (access enforcement is implemented as policy); AC-4 (information flow enforcement is the segmentation control); CM-7 (least functionality limits flows to what is needed); SC-7 (boundary protection is segmentation)
- **DORA** — Art.9 (ICT security includes segmentation of critical assets)

79% of policies in enforce mode

Enforcement-mode policies are the difference between an audit narrative and a control. This ratio is the single best evidence the program is operational.

Compliance reinforcement. This capability supports:

- **HIPAA** — 164.308(a)(4) (information access management is enforced via policy); 164.312(a)(1) (access control is implemented as policy)
- **PCI-DSS** — 1.2.1 (network security controls are the segmentation evidence); 1.3 (no direct internet access to CDE requires enforced policy); 12.5.3 (segmentation effectiveness is tested annually)
- **NIST-800-53** — AC-3 (access enforcement is implemented as policy); AC-4 (information flow enforcement is the segmentation control); CM-7 (least functionality limits flows to what is needed); SC-7 (boundary protection is segmentation)
- **DORA** — Art.9 (ICT security includes segmentation of critical assets)

47 scopes defined

A scope hierarchy this deep means the segmentation model reflects organisational reality - prerequisite for least-privilege at scale.

Compliance reinforcement. This capability supports:

- **HIPAA** — 164.308(a)(1)(ii)(A) (risk analysis requires knowing what's in scope); 164.310(c) (workstation security depends on inventory)
 - **PCI-DSS** — 1.2.1 (network controls depend on knowing what they protect)
 - **NIST-800-53** — AU-2 (audit events presume coverage of every workload); SI-4 (system monitoring requires telemetry from every workload)
 - **DORA** — Art.8 (ICT risk management requires complete asset inventory); Art.9 (ICT security depends on knowing the estate)
-

What we'd recommend addressing

Why these matter beyond the score. The 4 items below together touch **7 not-yet-met controls** across **4 frameworks** (HIPAA, NIST-800-53, PCI-DSS, DORA). Each item lists the specific control IDs it would help close, so the work can be tracked back to a compliance line item.

Few absolute policies in place

Category: segmentation · Estimated posture uplift if addressed: +6 pts

Absolute policies are the right tool for crown-jewel isolation (PHI, cardholder data, regulated systems). Their absence indicates the segmentation strategy is still permissive-by-default.

Compliance impact if addressed. Closing this gap helps move:

- **HIPAA** — 164.312(e)(1) (transmission security relies on segmentation)
- **NIST-800-53** — SC-7(5) (deny-by-default requires absolute policies)

64 policies remain in monitor mode

Category: segmentation · Estimated posture uplift if addressed: +3 pts

Monitor-mode policies generate evidence but do not block lateral movement. Promoting reviewed policies to enforce directly improves the segmentation score component.

Compliance impact if addressed. Closing this gap helps move:

- **HIPAA** — 164.312(e)(1) (transmission security relies on segmentation)
- **NIST-800-53** — SC-7(5) (deny-by-default requires absolute policies)

7 critical CVEs on workloads

Category: hygiene · Estimated posture uplift if addressed: +3 pts

CSW correlates package CVEs to running processes. Each critical CVE on an internet-reachable workload is a candidate for escalation to patching or compensating policy.

Compliance impact if addressed. Closing this gap helps move:

- **PCI-DSS** — 11.3 (vulnerability scanning evidence drives this control)
- **DORA** — Art.10 (detection of ICT vulnerabilities)

208 workloads without an agent

Category: visibility · Estimated posture uplift if addressed: +1 pts

Workloads outside agent coverage are invisible to flow analytics, ADM, and policy enforcement. Closing this gap unlocks visibility-driven controls in every framework.

Compliance impact if addressed. Closing this gap helps move:

- **PCI-DSS — 11.3** (penetration-test scope is set by inventory)
-

Suggested 30-day plan

The plan is sequenced so each week's work feeds the next; weeks 1-2 are foundation moves, week 3 is the highest-leverage policy promotion, and week 4 closes the loop with a re-measurement.

Wk	Action	Owner	Addresses
1	Close agent-coverage gap. Identify the 208 workloads without an agent. Triage into: (a) deploy now, (b) excluded by policy, (c) decommission. Track in a single ticket; aim for 95%+ coverage.	Platform Engineering	208 workloads without an agent
2	Author absolute policies for crown jewels. Identify the top 3 crown-jewel scopes (databases of regulated data, payment systems, PHI stores). Draft absolute policies that take precedence over inherited rules.	Security Architecture	Few absolute policies in place
3	Promote vetted policies to	Security Operations	64 policies remain in monitor

Wk	Action	Owner	Addresses
	enforce mode. Run the 30-day flow review on monitor-mode policies for top 3 scopes. Promote those with no false-positive flow violations to enforce.		mode
4	Address top critical CVEs. Pull the CSW vulnerability dashboard, sort by internet exposure + severity, dispatch top 10 to patching or compensating-policy workstreams.	Vulnerability Management	7 critical CVEs on workloads
5	Refresh evidence and report. Re-run csw-insights against the tenant. Compare posture score to baseline; share delta with steering committee.	Compliance / GRC	—

How CSW shows up across the frameworks you care about

For each framework below, the runbooks and reports in CSW-Compliance-Mapping walk through the specific controls this evidence supports. The numbers here are the *current* state of controls evaluated in this tenant.

Framework	Controls evaluated	Met	Coverage
HIPAA	7	6	86%
PCI-DSS	6	5	83%
NIST-800-53	8	7	88%

Framework	Controls evaluated	Met	Coverage
DORA	4	3	75%

Demo-able artefacts

The same evidence bundle that produced this report can also drive:

- **ADM (Application Dependency Mapping) walk-through** — visualise the highest-blast-radius workloads we identified.
- **Policy what-if** — replay 24h of flow data against a candidate policy to show enforcement impact before promoting.
- **Vulnerability dashboard** — sort the critical CVEs above by internet exposure to pick the top 10 patching candidates.
- **Auditor-ready evidence bundle** — the signed JSON used to render this report drops directly into the framework runbooks.

What we'd like to do next

1. Walk through the top 3 risks above with your platform/security teams.
2. Pick one risk to address this sprint; re-run `csw-insights` after.
3. Use the resulting before/after delta as the proof point for the wider rollout business case.

Materials, scripts, and templates are in CSW-Tenant-Insights. The underlying compliance narrative is in CSW-Compliance-Mapping. The evidence collection runs from CSW-API-Compliance-Automation.